

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

NexusTech Solutions — Policy Overhaul Simulation

Week 2 Practical Laboratory Report · Developing Security Policies and Procedures

Course	GRC102 – Information Security Governance
Module	Module 2 – Developing Security Policies and Procedures
Week	Week 2: 12–18 September 2026
Role Assumed	Information Security Manager, NexusTech Solutions
Student Name	Abigail Silas
Registration Number	C11/26/CGRCE/17260
Submission Date	18 September 2026

Table of Contents

1. Laboratory Scenario and Role
2. Evidence Bundle 1 — Policy Hierarchy and Categorisation (Task 1)
3. Evidence Bundle 2 — Acceptable Use Policy (Task 2)
4. Evidence Bundle 3 — User Access Request Procedure (Task 3)
5. Evidence Bundle 4 — Communication and Training Plan (Task 4)
6. Evidence Bundle 5 — Policy Review and Maintenance Memo (Task 5)

1. Laboratory Scenario and Role

NexusTech Solutions is a medium sized software development firm that focuses on cloud-based ERP solutions. With the expansion of their workforce from 50 to 250 people and taking on high profile clients in financial services and healthcare, they have outgrown the need for the five-year old "IT Rules" document where the high level intent, configuration information, and recommendations are all rolled into one non-sustainable document.

The following report will be written from the position of an Information Security Manager of NexusTech Solutions. Using the Security Policy Development Lifecycle method, this report will provide replacement of the legacy document by creating the policy hierarchy in response to the mandate from the CEO Marcus Vance. The following five task will be described as the Evidence Bundles in accordance with the laboratory's submission requirements.

2. Evidence Bundle 1 — Policy Hierarchy and Categorisation (Task 1, 20 marks)

IT Director Sarah Jenkins recently discovered a document titled “Password Policy” that mixed step-by-step Active Directory reset instructions with policy-level intent — a symptom of the same documentation problem found across NexusTech's “IT Rules.” The purpose of this task is to define the documentation hierarchy precisely and to demonstrate, against real draft statements, how each layer is identified in practice.

2.1 Hierarchy Definition Table

Document Type	Purpose	Authority	Mandatory / Recommended	Level of Detail
Policy	States high-level intent, principles and management commitment. Establishes the organisation's position on a topic and the “why” behind it.	Approved by executive leadership (CEO). Organisation-wide authority; binds all employees.	Mandatory	High-level and technology-agnostic; rarely changes.
Standard	Specifies mandatory, measurable requirements that implement a policy — specific technologies, configurations or numeric thresholds.	Approved by IT/Security leadership under delegated policy authority.	Mandatory	Specific and quantifiable, but not sequential instructions.
Guideline	Offers recommended practices to help users make good decisions where a standard does not dictate one exact approach.	Issued by IT/Security as advisory guidance.	Recommended (best-effort)	Flexible and contextual; presents options rather than rules.
Procedure	Provides step-by-step instructions for performing a specific task in support of a policy or standard.	Owned by the operational team that performs the task (e.g., IT Helpdesk).	Mandatory whenever the associated task is performed	Highly detailed, sequential and technical.

2.2 Categorisation of the Documentation Brainstorming List

Each of the eight draft statements collected during discovery is classified below against the hierarchy defined in Section 2.1, with a one-sentence justification for each classification.

#	Draft Statement	Classification	Justification
1	All employees must use MFA when accessing the corporate network remotely.	Standard	Sets a mandatory, specific technical control (MFA) that implements the organisation's broader access-control policy intent.
2	To configure MFA on your mobile device, download the Authenticator app, scan the QR code, and enter the six-digit code.	Procedure	Gives sequential, task-level instructions for completing one specific action — the hallmark of a procedure, not a policy.
3	It is recommended that developers use parameterised queries to reduce SQL injection risk.	Guideline	Advisory language (“recommended”) offering a best-practice technique without mandating a single implementation.
4	NexusTech is committed to protecting the confidentiality, integrity and availability of all client data.	Policy	A high-level statement of intent and principle with no operational detail — the organisation's “why.”
5	All corporate laptops must have full-disk encryption enabled using BitLocker (Windows) or FileVault (macOS).	Standard	Mandatory and precisely specified — names the exact required control and technology per platform.
6	Employees should avoid connecting to public, unsecured Wi-Fi networks when travelling.	Guideline	“Should” signals advisory, non-mandatory practice rather than an enforceable requirement.
7	In the event of a suspected security breach, employees must immediately contact the IT Helpdesk at extension 5555.	Procedure	A specific, actionable step (an exact contact method) that operationalises the policy-level duty to report incidents; the underlying obligation to report belongs in policy, but this level of operational detail belongs in a procedure/quick-reference.
8	Passwords must be a minimum of 14 characters and contain at least one uppercase letter, one lowercase letter, one number and one special character.	Standard	Mandatory and precisely measurable password-complexity parameters supporting the organisation's access-control policy.

2.3 Policy Hierarchy Diagram

Figure 1 illustrates how a single policy statement flows into the standard, procedure and guideline layers that support it, using Statement 1 (the MFA requirement) as a worked example.

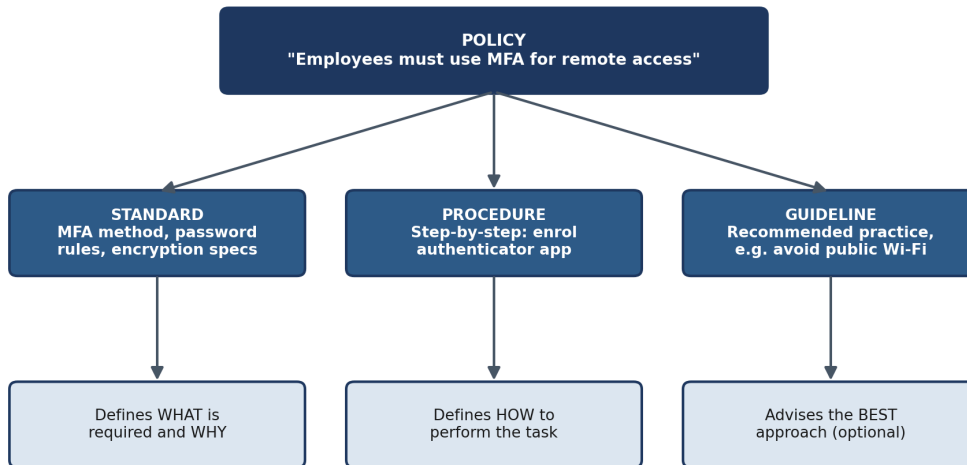


Figure 1. NexusTech Solutions — Policy Documentation Hierarchy

3. Evidence Bundle 2 — Acceptable Use Policy (Task 2, 25 marks)

NexusTech currently has no formal rules governing company-provided devices or acceptable behaviour on the corporate network; unauthorised software downloads and extensive personal use have measurably increased malware and compliance risk. The Acceptable Use Policy (AUP) below closes this gap. It deliberately states what users must and must not do, and does not repeat the step-by-step technical procedures that belong in supporting documents.

Document Control

Policy Title	Acceptable Use Policy
Version	1.0
Policy Owner	Information Security Manager
Approval Authority	Marcus Vance, Chief Executive Officer
Effective Date	18 September 2026
Review Date	18 September 2027
Classification	Internal

1. Purpose

This Acceptable Use Policy (“Policy”) establishes the rules governing appropriate use of NexusTech Solutions (“NexusTech” or “the Company”) information systems, networks, devices, applications and data. It exists to protect the confidentiality, integrity and availability of company and client information — including the sensitive financial and healthcare data NexusTech now processes on behalf of its clients — while enabling employees to use company resources productively. It reduces the risk of malware infection, data loss, unauthorised disclosure and compliance failure created by inconsistent or informal usage practices.

2. Scope

This Policy applies to all NexusTech employees, contractors, interns and temporary workers (“Users”) who access, use or manage NexusTech-owned or NexusTech-managed devices, accounts, networks, applications, cloud services or data, regardless of location. It covers company-issued laptops and mobile devices, the corporate network (on-site and remote/VPN), email and collaboration platforms, business applications, and any personally owned device authorised to access NexusTech resources. This Policy operates alongside, and does not replace, the Access Control, Data Classification and Handling, and Incident Response requirements referenced throughout the wider policy suite.

3. Policy Statements

3.1 Acceptable Use

- Users must use NexusTech systems, accounts and data primarily for legitimate business purposes in support of their role.
- Users must keep login credentials confidential and must not share accounts, passwords or authentication tokens with any other person.
- Users must lock or log off any device before leaving it unattended.
- Users must install security updates and patches promptly when prompted, or make devices available for IT-managed patching.
- Users must report lost or stolen devices, suspected malware, phishing attempts or other suspected security incidents to the IT Helpdesk immediately.
- Users must use only software, cloud services and storage locations approved by IT/Security — including approved cloud platforms — to store or process NexusTech or client data.

3.2 Reasonable Personal Use

- Limited, incidental personal use of company devices and the corporate network (e.g., checking personal email during breaks) is permitted provided it does not interfere with job performance, consume disproportionate network resources, or violate this Policy.
- Personal use must never involve accessing prohibited content (Section 3.3), installing unauthorised software, or storing personal files containing client or company confidential data.
- Management reserves the right to limit or withdraw personal-use allowances for individual users or teams where misuse, performance impact or risk is identified.

3.3 Prohibited Activities — Users must not:

- Download, install or execute unauthorised software, browser extensions or applications on company-owned devices without prior IT/Security approval.
- Disable, bypass or attempt to circumvent security controls, including endpoint protection, encryption, multi-factor authentication (MFA) or content filtering.
- Use company systems to access, store, transmit or distribute illegal, discriminatory, harassing, obscene or otherwise offensive material.
- Send client-confidential or sensitive personal data to personal or unapproved third-party accounts, including personal cloud storage or personal email.
- Connect unauthorised personal storage devices (e.g., USB drives) to company systems without IT authorisation.
- Use company resources for outside commercial activity, political campaigning or personal financial gain.

- Attempt to access systems, accounts or data for which the user has not been granted authorisation, including testing or probing NexusTech or client systems without written authorisation from the Information Security Manager.
- Represent personal opinions as official NexusTech positions on public or social platforms while identifying their employment with NexusTech, unless authorised to do so.

4. Roles and Responsibilities

- All Users — comply with this Policy, complete required security-awareness training, and report suspected violations or incidents promptly.
- Line Managers — reinforce acceptable-use expectations within their teams, support reasonable exception requests, and escalate suspected violations to HR and the Information Security Manager.
- IT/Security Team — implement and maintain technical controls supporting this Policy (endpoint protection, content filtering, monitoring); investigate suspected violations and incidents; maintain the exception log.
- Human Resources — support disciplinary processes arising from confirmed policy violations in accordance with employment policy and applicable law.
- Information Security Manager (Policy Owner) — maintains, reviews and updates this Policy, and reports on compliance and violation trends to the CEO.

5. Compliance and Enforcement

Compliance with this Policy is mandatory for all Users in scope. IT/Security may monitor use of company systems, networks and accounts, within the bounds of applicable law and with appropriate notice, to verify compliance and to detect and respond to security incidents. Confirmed violations may result in disciplinary action up to and including termination of employment or contract, and, where unlawful activity is involved, referral to law enforcement. Managers and IT/Security must document all confirmed violations and remediation actions.

6. Exceptions

Any request for an exception to this Policy must be submitted in writing to the Information Security Manager, describing the business need, the specific requirement to be waived, the proposed compensating control, and the requested duration. Exceptions require documented approval from the Information Security Manager (and, for higher-risk requests, the CEO), must be time-bound (maximum 12 months, renewable on review), and must be logged in the Policy Exception Register. Exceptions are reviewed at least annually and revoked immediately if the associated risk becomes unacceptable or the compensating control fails.

7. Approval and Review

This Policy will be reviewed at least annually, or earlier upon material change to NexusTech's technology environment, regulatory obligations or risk profile, in accordance with the Policy Review and Maintenance process described in Evidence Bundle 5.

Approved by	Marcus Vance, Chief Executive Officer
Signature	_____
Date	_____ 18-9-2026 ____

4. Evidence Bundle 3 — User Access Request Procedure (Task 3, 20 marks)

With the new policy framework requiring all access to be formally requested, approved and provisioned, the informal email/chat practice previously used by the Helpdesk must be replaced. The procedure below gives Helpdesk technicians a consistent, auditable sequence of steps to follow for every access request.

Document Control

Procedure Title	User Access Request Procedure
Procedure Owner	IT Helpdesk Manager
Supports	Access Control Policy
Version	1.0
Effective Date	18 September 2026

1. Purpose

This procedure defines the consistent, auditable steps Helpdesk technicians must follow to receive, verify, approve, provision and record all requests for access to NexusTech systems, applications and data, ensuring access is granted only following proper authorisation and on a least-privilege basis.

2. Scope

Applies to all requests for new user accounts, changes to existing access (role changes, additional permissions), and access removal, for employees, contractors and third parties across NexusTech's corporate network, business applications, cloud platforms and shared data repositories.

3. Prerequisites

- Requestor must be an active NexusTech employee, contractor or approved third party with an assigned manager or engagement owner.
- Access requests must be submitted through the approved IT Service Management (ITSM) ticketing system; informal requests via email, chat or verbal instruction must not be actioned.
- The technician must hold Helpdesk-tier system access and be listed on the current Authorised Provisioning Roster.
- The relevant system/data owner must be identified in the Access Control Matrix before provisioning can occur.

4. Procedure Steps

Step 1 — Request Intake

- 1.1 The requestor (employee, manager, or HR on behalf of a new hire) submits an Access Request ticket through the ITSM portal, selecting the specific system(s) or data resource(s) and the business justification.
- 1.2 The technician confirms the ticket contains all mandatory fields — requestor identity, target system, access level requested, business justification and requested start date. Incomplete tickets are returned to the requestor.

Step 2 — Approval Verification

- 2.1 The technician confirms that the requestor's direct manager (for role-based access) or the designated data/system owner (for sensitive or elevated access) has approved the request within the ticketing workflow.
- 2.2 For access to systems holding client financial or healthcare data, the technician confirms a second approval from the Information Security Manager, consistent with the Access Control Policy's segregation-of-duties requirement.
- 2.3 Requests lacking required approval are placed on hold and returned to the approver with a reminder; provisioning must not proceed without documented approval.

Step 3 — Access Determination and Least-Privilege Check

- 3.1 The technician cross-references the requested access against the Role-Based Access Control (RBAC) matrix to identify the standard permission set for the requestor's job role.
- 3.2 Where the request matches a standard role, the technician proceeds to provisioning using the pre-defined permission template.
- 3.3 Where the request exceeds the standard role, the technician escalates to the Information Security Manager for a risk review before provisioning, granting only the minimum access necessary for the stated business purpose.

Step 4 — Account Creation

- 4.1 The technician creates the new account (or modifies the existing account) in the identity management system using the approved naming convention and a temporary, single-use initial credential.
- 4.2 The technician assigns the user to the appropriate security group(s)/role(s) corresponding to the approved permission set; MFA enrolment is initiated for all new accounts.
- 4.3 For third-party or contractor accounts, the technician sets an account expiration date matching the engagement end date recorded on the ticket.

Step 5 — Role-Based Permission Assignment and Least-Privilege Confirmation

- 5.1 The technician performs a post-provisioning check comparing granted permissions to the approved request to confirm no excess access was inadvertently applied.
- 5.2 Any discrepancy is corrected immediately and documented in the ticket.

Step 6 — User / Manager Notification

- 6.1 The technician notifies the requestor and their manager that access has been provisioned, including instructions for initial login and mandatory password/MFA setup.
- 6.2 For elevated or sensitive access, the technician also notifies the Information Security Manager for awareness.

Step 7 — Evidence Capture and Ticket Closure

- 7.1 The technician attaches to the ticket: the original request, manager/owner approval record, permission set applied, and provisioning timestamp.
- 7.2 The ticket is marked "Resolved" only once all evidence is attached and the requestor has confirmed successful access, then closed after a 48-hour confirmation window.

Step 8 — Emergency or Exceptional Requests

- 8.1 Emergency access (e.g., during an active incident) may be granted verbally by the Information Security Manager or on-call IT Director, but must be logged in the ITSM system retroactively within 24 hours with full justification.
- 8.2 Emergency access is granted for a maximum of 72 hours and automatically expires unless converted to a standard, fully-approved request.
- 8.3 All emergency access grants are reviewed by the Information Security Manager within 5 business days.

Step 9 — Record Retention and Audit Trail

- 9.1 All access request tickets, approvals and provisioning records are retained in the ITSM system for a minimum of three (3) years, or longer where required by client contractual or regulatory obligations (e.g., SOC 2 evidence retention).
- 9.2 Access records are made available to internal audit, external auditors and compliance reviewers on request.
- 9.3 Quarterly, the IT Helpdesk Manager reconciles a sample of provisioned access against approved tickets to confirm procedural adherence, reporting exceptions to the Information Security Manager.

5. Evidence Bundle 4 — Communication and Training Plan (Task 4, 20 marks)

The AUP and User Access Request Procedure have been approved by the CEO. Simply emailing a PDF is not sufficient for a workforce of 250 people spread across engineering, client-facing and administrative functions, so the plan below sets out how the new AUP will be communicated, taught, acknowledged and measured across four distinct audiences.

5.1 Audience, Message, Channel and Measurement

Audience	Key Message	Channel	Owner	Timing	Acknowledgement	Success Measure
General Employees	You are personally responsible for protecting NexusTech and client data — know what's acceptable, what's prohibited, and how to report a concern.	All-hands announcement, email, intranet policy hub, mandatory e-learning module.	Information Security Manager (content) / HR (scheduling)	Week 1 announcement; Week 2 training completion deadline.	Digital attestation in the LMS (“I have read and agree to comply with the AUP”) required to retain system access.	≥ 95% attestation within 15 days; ≥ 80% average knowledge-check score.
IT & Helpdesk Staff	The AUP defines what you must enforce and monitor technically; know the escalation and exception paths.	Dedicated technical briefing session, reference runbook, Q&A workshop.	IT Director / Information Security Manager	Week 1, prior to general rollout.	Sign-off on the technical runbook plus completion of the enforcement-tool walkthrough.	100% sign-off before go-live; fewer misrouted policy queries after 30 days.
Management / Team Leads	You are accountable for reinforcing the AUP within your team and for approving reasonable exceptions.	Management briefing, manager talking-points memo, inclusion in the monthly leadership meeting.	Information Security Manager, with CEO sponsorship	Week 1, before the general employee announcement.	Manager attestation plus confirmation that team completion is being tracked.	100% manager attestation; team completion reviewed at 30/60/90 days.
Contractors & Third Parties	Access to NexusTech systems is conditional on compliance with the AUP for the	Onboarding/engagement paperwork, condensed one-page policy summary, contractual	Procurement / Vendor Management, with IT Security review	At onboarding and before any system access is	Signed acknowledgment as part of the engagement contract, tracked in the vendor	100% of active contractors with an on-file signed acknowledgment.

Audience	Key Message	Channel	Owner	Timing	Acknowledgement	Success Measure
	duration of your engagement.	acknowledgement clause.		granted; ongoing.	management system.	

5.2 Rollout Timeline

- Week 1, Day 1–2: CEO-sponsored announcement (all-hands session and email); management briefing; Helpdesk technical briefing.
- Week 1–2: Full policy and FAQ published to the intranet; mandatory e-learning module opens.
- Week 2, end: Deadline for employee attestation and knowledge-check completion.
- Week 3: Completion report presented to the Information Security Steering Committee; reminder campaign for outstanding attestations.
- Day 30 / 60 / 90: Follow-up compliance check and a brief pulse survey or phishing-style scenario quiz to test retained understanding.

5.3 Measures of Rollout Effectiveness

- Attestation / acknowledgement completion rate — target $\geq 95\%$ within 15 days of rollout.
- Knowledge-check / quiz average score — target $\geq 80\%$, used as a proxy for comprehension rather than mere completion.

5.4 Escalation of Non-Compliance or Repeated Misunderstanding

Employees who do not complete attestation by the deadline receive an automated reminder at day 7, a manager escalation at day 10, and an IT Security access-restriction review at day 15 if still outstanding. Repeated misunderstanding of the same provision across a team — for example, recurring questions or errors traced to one policy clause — triggers a targeted refresher session for that team and is reported to the Information Security Steering Committee as a training-effectiveness signal, kept separate from the individual disciplinary process described in Section 5 of the AUP.

6. Evidence Bundle 5 — Policy Review and Maintenance Memo (Task 5, 15 marks)

To	Information Security Steering Committee
From	Abigail Silas, Information Security Manager
Date	18 September 2027
Re	Triggered Review of the Acceptable Use Policy — Cloud Migration and Personal-Cloud Data Sharing Incident

There have been two major triggers since the acceptance of AUP on 18 September 2026 which require conducting a formal review prior to the annual review cycle. The first trigger is the fact that NexusTech's move to cloud-based services by migrating their main database to AWS has resulted in a material change of the technology environment covered by the AUP as currently, the policy's prohibited activity and acceptable use language does not cover such things as cloud storage and services, or a shared responsibility approach. The second trigger is a security incident when one of the employees has disclosed a confidential document using his or her own cloud storage which means that even if the current language of the AUP is directionally correct, it did not prove to be memorable enough to prevent a security violation. Thus, both incidents fall under the criteria for early review of the policy: a material change of the technology environment and a security incident.

The review shall be conducted according to NexusTech's standard policy maintenance procedures. The Information Security Manager shall schedule a meeting with the IT Director, the Cloud/DevOps manager, the data protection liaison, and one Helpdesk representative to conduct an analysis of the incident's root cause and its impact on the cloud migration from the perspective of data management. The review process shall involve conducting a brief risk analysis of how current AUP language differs from the proposed cloud migration model as well as from the manner in which the personal cloud sharing incident was carried out, as well as reviewing the evidence and closure reports related to the incident and consulting the Engineering department and the employee's business unit about the revised wording being enforceable and realistic.

Following the findings, the following updates are recommended for inclusion in the next AUP update. Firstly, include a "Approved Cloud Services" clause in sections 3.1 and 3.3, whereby all approved cloud storage and collaboration solutions for NexusTech will be listed, and explicitly stating the prohibition of using any other cloud storage services, personal email services, and any other consumer cloud solutions that have not been authorized by NexusTech for handling company/client information. Secondly, include an explanation in section 3.1 whereby the term "IT/Security-approved storage locations" includes cloud-based storage as well.

The Information Security policy owner, the Information Security Manager, will be responsible for the review and approval of the updated AUP (version 1.1) which will proceed along the standard review and approval route: Steering Committee review and CEO sign-off, before republication and targeted re-attestation campaign. The AUP will continue to be reviewed annually and will be triggered for early review if there is any of the following material change in NexusTech's technology or cloud environment: if there is a confirmed security incident involving a policy provision; a significant regulatory or client contractual change (in particular given NexusTech's financial and healthcare-sector client base); or organisational growth of 25% or more on headcount since the last review.